

UPANZI

DIGITAL PUBLIC INFRASTRUCTURE

NETWORK

BLUE TEAM ASSESMENT

INCIDENT REPORT

Authors:

Alvina Minja, Afsanat Ineza, Emmanuel Iduh, Moise Iradukunda Ingabire

November 2025

Executive Summary	3
Technical Analysis	4
Affected Systems and Data:	4
Evidence Source and Analysis	4
ELK (ElasticSearch, Logstash and Kibana) Security Alerts Analysis	4
Wazuh Dashboard Analysis	13

EXECUTIVE SUMMARY

- **Reference ID:** 05100-GRP-ASS2
- **Severity Level:** Medium
- **Investigation Status:** Under Review

- **Incidence Summary:** Between October 22 and November 10, the server secops-upanzi-matrix-3 was attacked by multiple computers within the network. The initial reconnaissance activity aimed at mapping the network quickly escalated into aggressive intrusion attempts. Unfortunately, this activity succeeded, and an unauthorized user was able to log into the system.

- **Critical Findings:**
 - **Confirmed Compromise:** On October 22, an unauthorized login (HTTP 200) was recorded from IP 172.29.106.179, following a series of credential-stuffing attempts.
 - **Extensive Enumeration Detected:** The system logged over 100,000 'Page Not Found' (404) events, indicative of automated scanning to identify hidden or unlinked directories.
 - **Internal Network Probes Detected:** Infected internal hosts (e.g., 172.29.104.73) performed unauthorized SSH scans and port probes across the network using invalid credentials.
 - **SQL Injection During Brute-Force Attempts:** Analysis of logs reveals the injection of malformed SQL queries into login fields, coinciding with ongoing brute-force attempts.

- **Incidence Impact:** The primary impact of this incident is a verified breach of confidentiality, as the attacker successfully bypassed authentication mechanisms to gain unauthorized access to sensitive system resources. This breach could potentially expose confidential data or compromise critical services. Operationally, the server was subjected to extreme load and log saturation from over 100,000 automated requests, which significantly could hinder the ability of security teams to monitor activity in real time and detect emerging threats. Furthermore, the incident exposed a failure in internal controls, as potential internal attackers were able to freely launch suspicious SSH and port scanning attacks against the target server without being blocked by network segmentation controls.

- **Action Plan and Remediations:** The response plan includes immediate isolation of the affected host and the enforcement of firewall rules to block all malicious IP addresses. Compromised credentials will be revoked, and a thorough audit of all active sessions will be conducted to ensure account integrity. Authentication gateways will be strengthened through throttling mechanisms, and SSH access will be restricted to key-only verification. Additionally, strict network segmentation will be implemented to prevent unrestricted lateral movement between internal hosts, reducing the risk of further compromise.

TECHNICAL ANALYSIS

Affected Systems and Data:

Target system

- Host Name: secops-upanzi-matrix-3
- Ip Address: 172.29.108.123
- Platform: Ubuntu

Attacker Sources:

- 172.29.108.82
- 172.29.108.57
- 172.29.106.179
- 172.29.105.25
- 172.29.106.110
- 172.29.104.73

Evidence Source and Analysis

ELK (ElasticSearch, Logstash and Kibana) Security Alerts Analysis

A query in the Security Alerts scoped to the host secops-upanzi-matrix-3 returned 26K+ alerts across five rules. Most detections originated from Network Traffic and ML Anomaly High Score, forming the primary focus of this review. Additionally, 24 alerts were generated under Potential Port Scanning Activity, indicating short-window bursts of multi-port connection attempts from the same host.

The summary of the observed alerts is provided below.

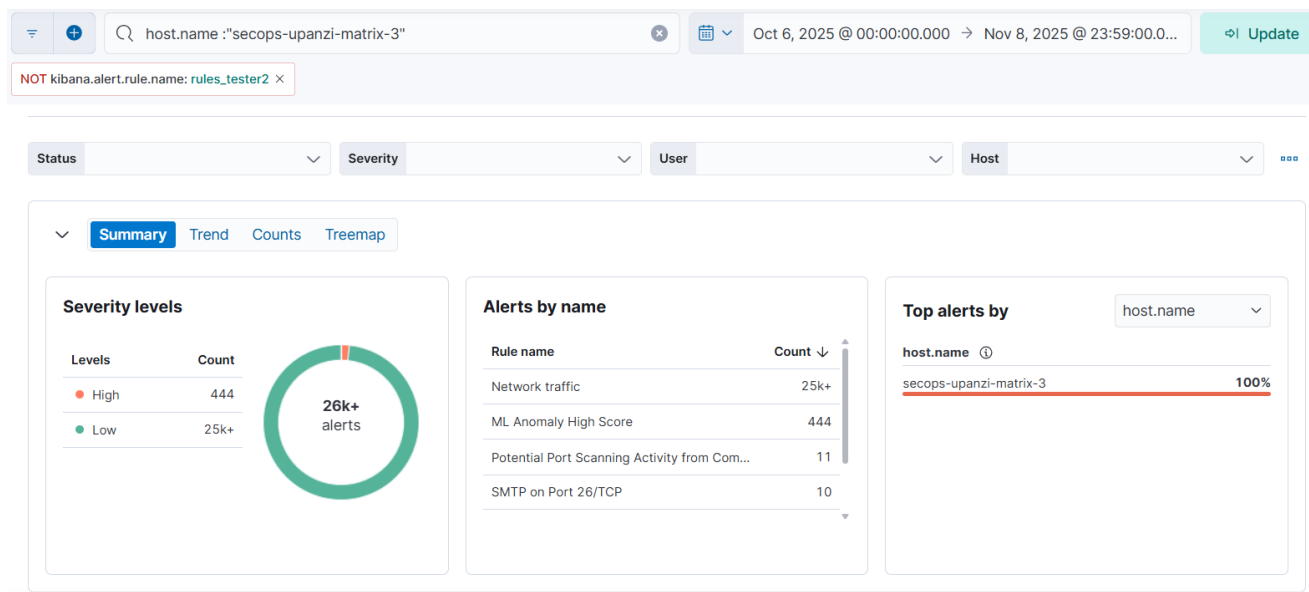


Figure 1: ELK Security Summary with 26K+ alerts.

Alert 1: Network Traffic

The first Network Traffic alert associated with the host was recorded on 28 October, with fluctuating activity continuing until 9 November. Between 1–3 November, the alert volume spiked significantly, exceeding 2,000 alerts within that short window.

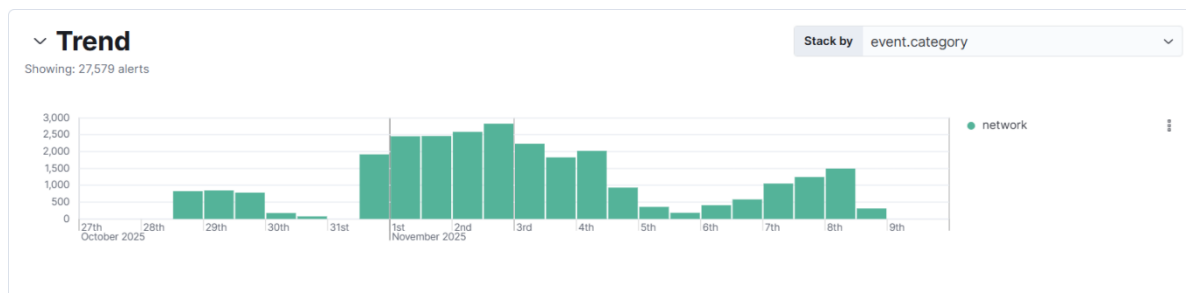


Figure 2: Network Traffic Alert spike from 1 to 3 Nov with over 2,000 events.

This Elastic rule triggered because the detection logic flags unusual or high-volume communication patterns that deviate from normal baselines, typically rapid or repeated connections, unexpected service interactions, or abnormal traffic flows between hosts. In this case, three hosts generated most of the activity: 172.29.108.82, 172.29.108.57, and 172.29.105.25, as shown below.

@timestamp	↑	Rule	host.name	source.ip	destination.ip
Oct 28, 2025 @ 13:01:54.390		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57
Oct 28, 2025 @ 14:45:15.750		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57
Oct 28, 2025 @ 15:41:26.763		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57
Oct 28, 2025 @ 15:55:27.409		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57
Oct 28, 2025 @ 16:25:29.349		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57
Oct 28, 2025 @ 17:47:32.260		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57
Oct 28, 2025 @ 18:08:32.899		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.57

Figure 3: Host 172.29.108.57 generating significant Network traffic.

@timestamp	↓	Rule	host.name	source.ip	destination.ip
Oct 28, 2025 @ 23:59:40.928		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82
Oct 28, 2025 @ 23:59:40.926		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82
Oct 28, 2025 @ 23:59:40.924		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82
Oct 28, 2025 @ 23:59:40.923		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82
Oct 28, 2025 @ 23:59:40.921		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82
Oct 28, 2025 @ 23:59:40.919		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82
Oct 28, 2025 @ 23:59:40.917		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.108.82

Figure 4: Host 172.29.108.82 contributing to elevated unusual traffic patterns.

@timestamp	↑	Rule	host.name	source.ip	destination.ip
Nov 3, 2025 @ 13:12:33.904		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.105.25
Nov 3, 2025 @ 14:15:49.657		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.105.25
Nov 3, 2025 @ 18:12:43.031		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.105.25
Nov 3, 2025 @ 18:12:43.032		Network traffic	secops-upanzi-matrix-3	172.29.108.123	172.29.105.25

Figure 5: Host 172.29.105.25 contributing to elevated unusual traffic patterns.

Network Packet capture Analysis

To determine whether this elevated traffic is legitimate or indicative of reconnaissance, the next step was to review packet-level activity. Network capture helps confirm what the host was communicating with and reveals patterns such as repeated port attempts, unusual protocols, or other behavior that may suggest scanning or lateral movement.

Reviewing HTTP activity within the same timeframe shows notable spikes in HTTP errors on 22 October, 25 October, 30 October, and 3 November. 404 errors accounted for the majority of these events, with counts exceeding 100,000, indicating unusually high levels of invalid or unreachable requests that required closer examination.

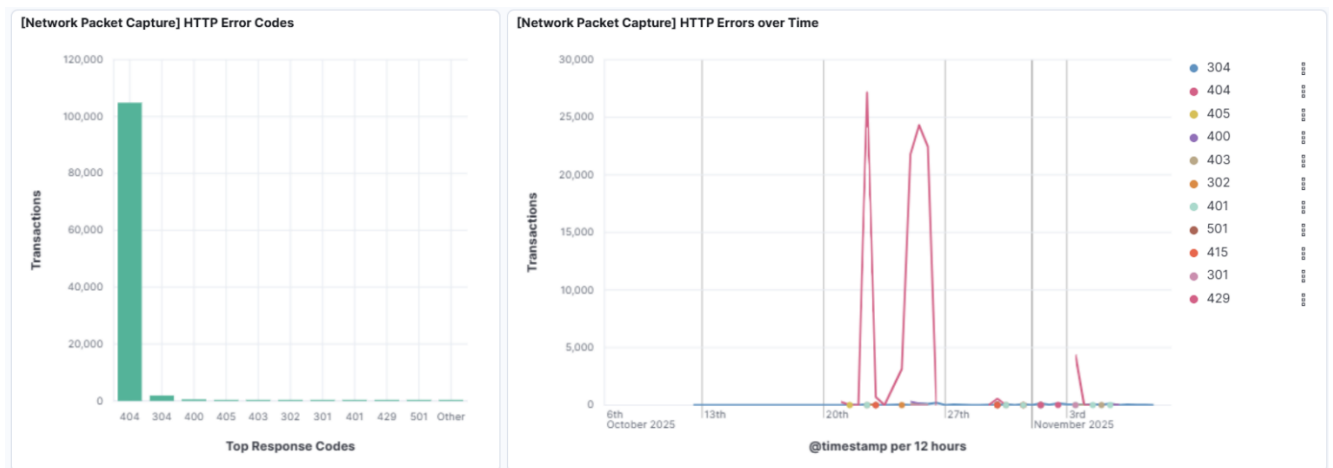


Figure 6: Packet-level capture shows unusual surges in HTTP errors on multiple days.

404 http error code analysis

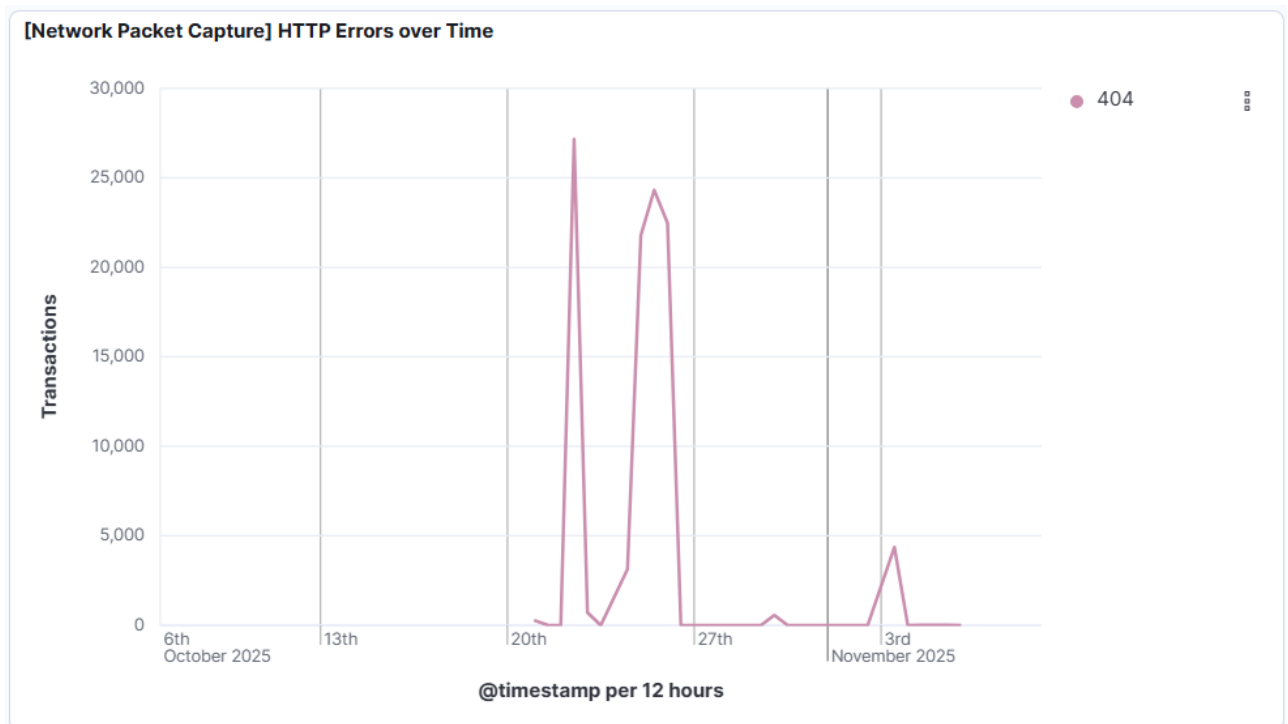


Figure 7: 404 bursts point to abnormal traffic.

The HTTP error timeline shows several sharp spikes in 404 responses, particularly between 22–26 October and again on 3 November, where error counts rose into the tens of thousands within a 12-hour window. These concentrated bursts indicate periods where the server received large volumes of requests for non-existent resources, suggesting automated activity rather than normal user behavior.

Further analysis of the 404 HTTP errors in Discover shows clear signs of directory brute-force activity, where numerous different paths were requested within milliseconds. This pattern indicates automated enumeration rather than normal user behavior. the same ip 172.29.105.25 was identified.

@timestamp	http.response.status_code	url.path	url.full	source.ip
Nov 3, 2025 @ 16:25:28.687	404	/wp-app	http://172.29.108.123:8445/wp-app	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/wp-app	http://172.29.108.123:8445/wp-app	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/wow	http://172.29.108.123:8445/wow	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/wow	http://172.29.108.123:8445/wow	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/workshop	http://172.29.108.123:8445/workshop	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/workshop	http://172.29.108.123:8445/workshop	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/world	http://172.29.108.123:8445/world	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/world	http://172.29.108.123:8445/world	172.29.105.25
Nov 3, 2025 @ 16:25:28.687	404	/workshops	http://172.29.108.123:8445/workshops	172.29.105.25

Figure 8: Directory brute-force activity detected from 172.29.105.25.

A second source IP (172.29.104.73) was also observed generating 404 errors within a short time frame, and although the volume was low, the specific directories requested (e.g., /HNAP1, /sdk, /evox/about) indicate lightweight web reconnaissance activity. These paths are commonly probed by automated scanners checking for exposed services.

@timestamp	http.response.status_code	url.path	url.full	source.ip
Nov 4, 2025 @ 19:31:13.956	404	/wp-config.php	http://172.29.108.123:8445/wp-config.php	172.29.104.73
Nov 4, 2025 @ 19:31:13.956	404	/wp-config.php	http://172.29.108.123:8445/wp-config.php	172.29.104.73
Nov 4, 2025 @ 18:41:36.706	404	/HNAP1	http://172.29.108.123:8445/HNAP1	172.29.104.73
Nov 4, 2025 @ 18:41:36.706	404	/HNAP1	http://172.29.108.123:8445/HNAP1	172.29.104.73
Nov 4, 2025 @ 18:41:36.702	404	/evox/about	http://172.29.108.123:8445/evox/about	172.29.104.73
Nov 4, 2025 @ 18:41:36.702	404	/evox/about	http://172.29.108.123:8445/evox/about	172.29.104.73
Nov 4, 2025 @ 18:41:36.694	404	/nmaplowercheck1762274440	http://172.29.108.123:8445/nmaplowercheck1762274440	172.29.104.73
Nov 4, 2025 @ 18:41:36.694	404	/nmaplowercheck1762274440	http://172.29.108.123:8445/nmaplowercheck1762274440	172.29.104.73
Nov 4, 2025 @ 18:41:36.694	404	/sdk	http://172.29.108.123:8445/sdk	172.29.104.73

Figure 9: Lightweight web reconnaissance detected from 172.29.104.73.

Further investigation within the same timeframe revealed brute-force attempts against the login page from 172.29.106.179, followed by requests consistent with SQL injection probing

@timestamp	http.response.status_code	url.path	url.full	source.ip
Oct 22, 2025 @ 19:01:13.052	404	/login	http://172.29.108.123:8445/login	172.29.106.179
Oct 22, 2025 @ 19:01:13.052	404	/login	http://172.29.108.123:8445/login	172.29.106.179
Oct 22, 2025 @ 19:01:13.045	404	/login	http://172.29.108.123:8445/login	172.29.106.179
Oct 22, 2025 @ 19:01:13.045	404	/login	http://172.29.108.123:8445/login	172.29.106.179
Oct 22, 2025 @ 19:01:13.030	404	/login	http://172.29.108.123:8445/login	172.29.106.179
Oct 22, 2025 @ 19:01:13.030	404	/login	http://172.29.108.123:8445/login	172.29.106.179
Oct 22, 2025 @ 19:01:13.023	404	/login	http://172.29.108.123:8445/login	172.29.106.179

Figure 10: Suspicious login Page brute force activity traced to 172.29.106.179.

@timestamp	http.response.status_code	url.path	url.full	url.port	source.ip
Oct 22, 2025 @ 18:31:15.010	404	/login,(SELECT (CASE WHEN (2458=2458) THEN (SELECT COUNT(*) FROM ALL_USERS T1,ALL_USERS ...	http://172.29.108.123:8445/login,%28SELECT%20%28CASE%20WHEN%20%282458=2458%29%20THEN%20%28SELECT%20C...	8,445	172.29.106.179
Oct 22, 2025 @ 18:31:14.995	404	/login',(SELECT (CASE WHEN (2458=2458) THEN (SELECT COUNT(*) FROM ALL_USERS T1,ALL_USERS ...	http://172.29.108.123:8445/login%27,%28SELECT%20%28CASE%20WHEN%20%282458=2458%29%20THEN%20%28SELECT%...	8,445	172.29.106.179
Oct 22, 2025 @ 18:31:14.995	404	/login',(SELECT (CASE WHEN (2458=2458) THEN (SELECT COUNT(*) FROM ALL_USERS T1,ALL_USERS ...	http://172.29.108.123:8445/login%27,%28SELECT%20%28CASE%20WHEN%20%282458=2458%29%20THEN%20%28SELECT%...	8,445	172.29.106.179
Oct 22, 2025 @ 18:31:14.971	404	/login,(SELECT (CASE WHEN (3160=3160) THEN DBMS_PIPE.RECEIVE_MESSAGE(CHR(90...	http://172.29.108.123:8445/login,%28SELECT%20%28CASE%20WHEN%20%283160=3160%29%20THEN%20DBMS_PIPE.REC...	8,445	172.29.106.179
Oct 22, 2025 @ 18:31:14.971	404	/login,(SELECT (CASE WHEN (3160=3160) THEN DBMS_PIPE.RECEIVE_MESSAGE(CHR(90...	http://172.29.108.123:8445/login,%28SELECT%20%28CASE%20WHEN%20%283160=3160%29%20THEN%20DBMS_PIPE.REC...	8,445	172.29.106.179
Oct 22, 2025 @ 18:31:14.944	404	/login',(SELECT (CASE WHEN (3160=3160) THEN DBMS_PIPE.RECEIVE_MESSAGE(CHR(90...	http://172.29.108.123:8445/login%27,%28SELECT%20%28CASE%20WHEN%20%283160=3160%29%20THEN%20DBMS_PIPE.	8,445	172.29.106.179
Oct 22, 2025 @ 18:31:14.944	404	/login',(SELECT (CASE WHEN	http://172.29.108.123:8445/login%27,%28SELECT%20%28CASE%20WHEN%20%283160=3160%29%20THEN%20DBMS_PIPE.	8,445	172.29.106.179

Figure 11: Suspicious SQL injection activity traced to 172.29.106.179

Overall, the Network Traffic alert reflects clear signs of early reconnaissance and probing activity within the environment. The combination of directory enumeration, high-volume 404 errors, and malicious login-page interactions lead to a structured attempt to assess and exploit the system. Key observations include:

1. Early Attack Phase: Directory brute-force attempts are consistent with initial reconnaissance techniques used to discover hidden endpoints and application structure.

2. High-Volume Scanning: The spike of 100,000+ 404 errors within short intervals, across many different paths, indicates systematic and automated mapping of the target's directory layout.
3. SQL Injection Probing: The brute-force attempts against the login page, followed by SQL injection-style requests, show a transition from passive enumeration to active exploitation attempts.
4. Pre-Attack Indicator: Together, these patterns signal a coordinated reconnaissance effort that likely served as a precursor to more advanced attacks, making the alert a critical early-warning signal.

Alert 2: ML Anomaly High score

This high-severity alert was triggered only within a short, concentrated window 7 to 8 November, but generated over 1,000 alerts, indicating repeated detections of behavior that deviated sharply from the host's normal baseline.

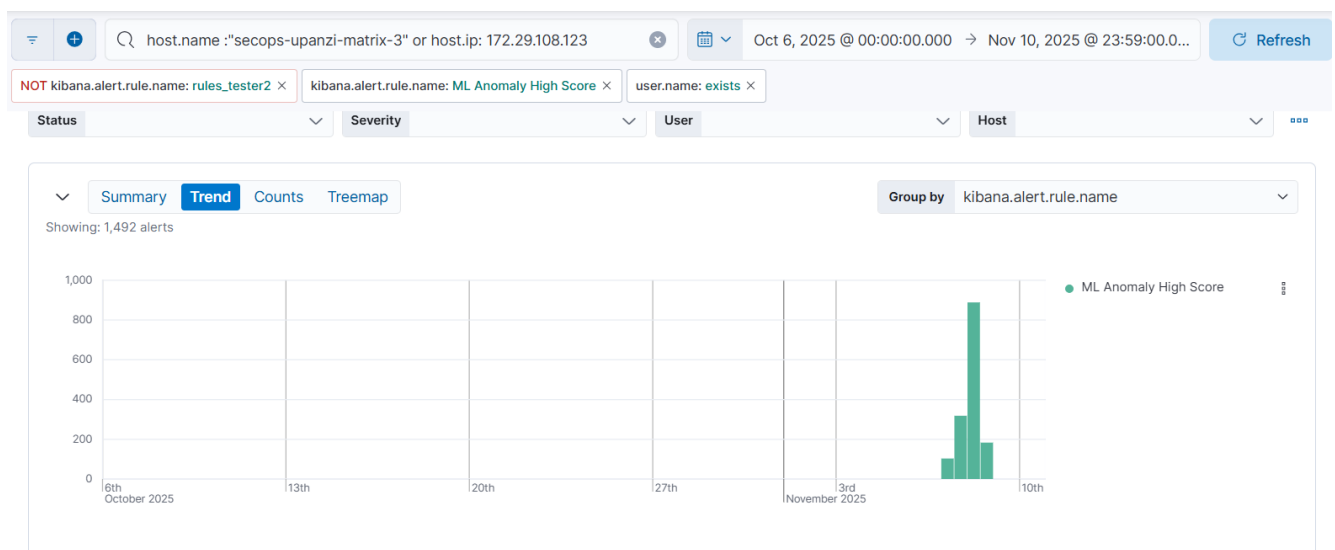


Figure 12: High-severity ML anomaly observed in a concentrated 7–8 Nov window.

A burst of ML Anomaly High Score alerts occurred within bursts of seconds in the timeline, all from host. The events involved repeated executions of `runc init`, `containerd-shim`, `docker-init`, and silent `wget --spider` checks, indicating a rapid sequence of container-related operations. While these processes are legitimate Docker components, they normally occur infrequently on this host, and their sudden concentration triggered the ML models designed to detect rare behavior. Overall, the activity appears unusual but not necessarily malicious, warranting verification against expected container operations.

☐ Actions	@timestamp	↑ process.command_line	Rule	user.name	host.name	process.name
☐	Nov 7, 2025 @ 10:09:06.106	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.107	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.108	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.109	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.110	/bin/sh -c wget -q --spider http://localhost:\$ELE...	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	sh
☐	Nov 7, 2025 @ 10:09:06.111	wget -q --spider http://localhost:80/config.json	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	wget
☐	Nov 7, 2025 @ 10:09:06.112	wget -q --spider http://localhost:80/config.json	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	wget
☐	Nov 7, 2025 @ 10:09:06.114	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.115	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.116	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.117	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.118	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.119	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.120	/bin/sh -c wget -q --spider http://localhost:\$ELE...	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	sh
☐	Nov 7, 2025 @ 10:09:06.123	/usr/libexec/docker/docker-init --version	ML Anomaly High Score	root	secops-upanzi-matrix-3	docker-init
☐	Nov 7, 2025 @ 10:09:06.124	/usr/libexec/docker/docker-init --version	ML Anomaly High Score	root	secops-upanzi-matrix-3	docker-init
☐	Nov 7, 2025 @ 10:09:06.126	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.127	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.128	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.129	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.130	runc init	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	6
☐	Nov 7, 2025 @ 10:09:06.131	/bin/sh -c wget -q --spider http://localhost:\$ELE...	ML Anomaly High Score	systemd-network	secops-upanzi-matrix-3	sh

Figure 13: Burst of unusual Docker activity flagged by ML models.

Alert 3: Potential Port Scanning Activity from Compromised Host

This rule generated 24 alerts, all occurring between 7–10 November, indicating repeated instances where a single host attempted connections across many ports within short time windows.

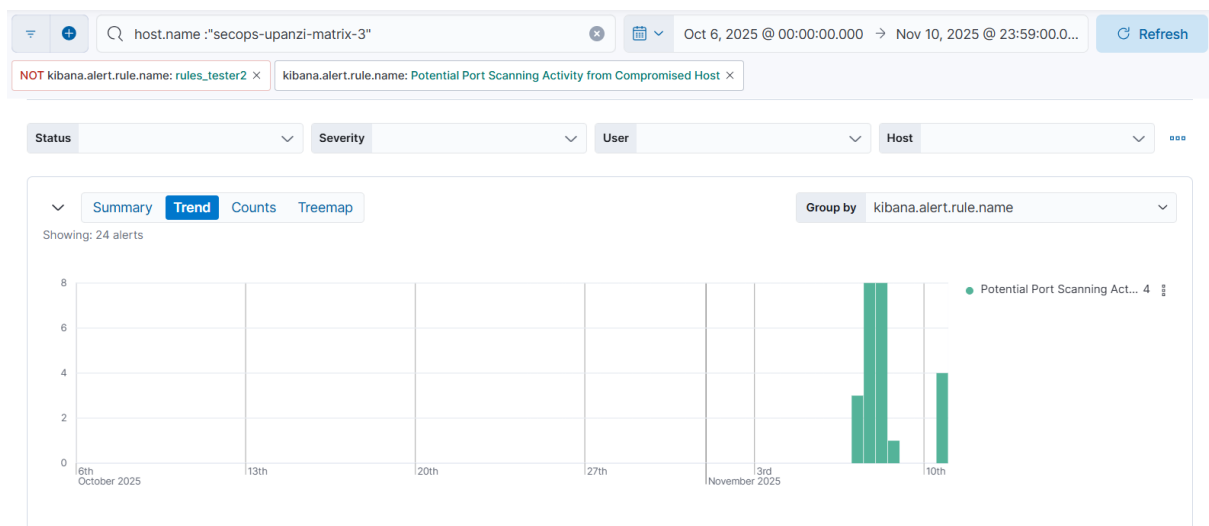


Figure 14: Repeated multi-port connection attempts triggered 24 alerts.

All 24 port-scanning alerts share the same pattern: the process `/usr/bin/wget` repeatedly initiated outbound connection attempts from the host `secops-upanzi-matrix-3` to the local address `::1`. The timestamps reveal that these attempts occurred in regular intervals, creating

a consistent behavioral footprint that Elastic flagged as potential scanning due to the repeated connection bursts.

@timestamp	↑ process.executable	Rule	destination.ip	host.name
Nov 7, 2025 @ 10:52:59.682	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 12:00:03.149	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 13:07:05.816	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 14:11:08.297	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 15:43:56.216	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 16:52:06.157	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 18:04:28.316	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 19:12:00.111	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 7, 2025 @ 22:15:32.466	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 00:17:03.401	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 01:17:03.227	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 05:17:43.844	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 07:19:10.468	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 08:19:10.909	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 09:19:16.843	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 10:25:10.685	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3
Nov 8, 2025 @ 11:33:08.343	/usr/bin/wget	Potential Port Scanning Act...	::1	secops-upanzi-matrix-3

Figure 15: Repeated connection attempts to ::1 identified as potential port scanning.

The alert details show that each event recorded a port count of at least 100, with most ranging between 118–119 unique ports being probed in a single burst. This indicates that /usr/bin/wget attempted connections across a wide spread of ports within a very short interval. The figure below shows one example alert where 118 distinct ports were targeted, meeting the threshold for Elastic’s multi-port scanning rule and explaining why these bursts were flagged as potential reconnaissance.

```
"@timestamp": "2025-11-08T06:19:10.909Z",
"cc": 120,
"port_count": 118,
"agent_count": 1,
"host.name": "secops-upanzi-matrix-3",
"agent.id": "a0b0d607-f5f8-446a-b7d0-4a6c6ac85f77",
"process.executable": "/usr/bin/wget",
"destination.ip": "::1",
"event.kind": "signal",
"kibana.alert.ancestors": [
```

Figure 16: Multi-port probing triggered potential reconnaissance alerts.

Overall, the activity reflects short bursts of broad port probing rather than sustained scanning, but the repeated multi-port attempts are still consistent with early reconnaissance behavior.

Wazuh Security Alerts Analysis

Alert: Attempted ssh using nonexistence user

Time	agent.name	data.srcip	data.srcuser	rule.description
> Nov 4, 2025 @ 19:23:58.469	secops-upanzi-matrix-3	172.29.104.73	rachel	sshd: Attempt to login using a non-existent user
> Nov 4, 2025 @ 19:23:24.435	secops-upanzi-matrix-3	172.29.104.73	rachel	sshd: Attempt to login using a non-existent user
> Nov 4, 2025 @ 19:14:52.005	secops-upanzi-matrix-3	172.29.104.73	rachel	sshd: Attempt to login using a non-existent user
> Nov 4, 2025 @ 19:14:43.995	secops-upanzi-matrix-3	172.29.104.73	rachel	sshd: Attempt to login using a non-existent user
> Nov 4, 2025 @ 19:14:37.989	secops-upanzi-matrix-3	172.29.104.73	rachel	sshd: Attempt to login using a non-existent user

Figure 17: SSH probing observed within a short window from 172.29.104.73.

Wazuh recorded multiple SSH authentication attempts from 172.29.104.73, where the remote machine (whose local username is rachel) attempted to log in to the host using a non-existent username. These attempts occurred within a small time window, indicating repeated probing from the same source.

Time	agent.name	data.srcip	data.srcuser	rule.description
> Nov 4, 2025 @ 20:21:01.762	secops-upanzi-matrix-3	172.29.106.168	matrix_admin	sshd: Attempt to login using a non-existent user
> Nov 4, 2025 @ 20:20:53.751	secops-upanzi-matrix-3	172.29.106.168	matrix_admin	sshd: Attempt to login using a non-existent user
> Nov 4, 2025 @ 20:20:47.745	secops-upanzi-matrix-3	172.29.106.168	matrix_admin	sshd: Attempt to login using a non-existent user

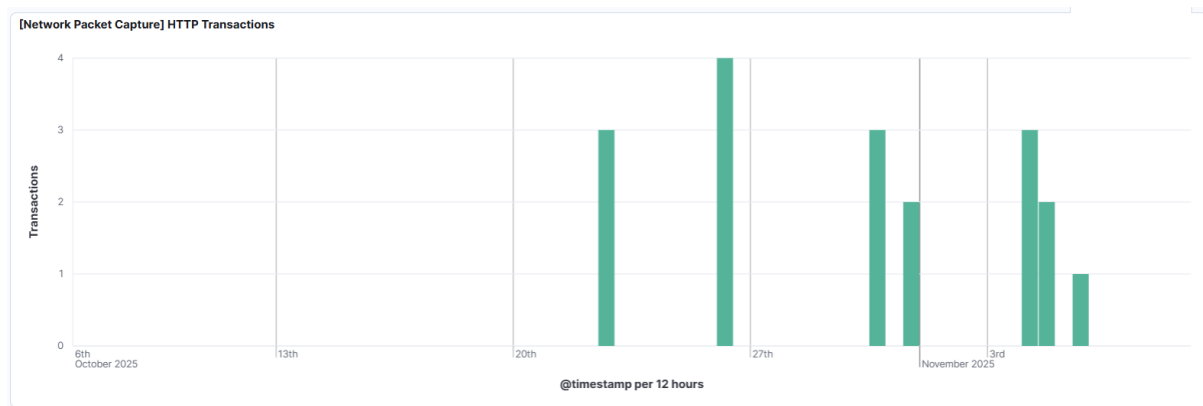
Figure 18: SSH probing detected from 172.29.106.168.

A second set of SSH authentication attempts came from 172.29.106.168, where the source machine's local user is matrix_admin. These attempts targeted our host and tried to log in using a non-existent user, similar to the earlier behavior seen from 172.29.104.73. The attempts occurred within seconds, indicating deliberate or automated probing. This could represent; compromised internal host activity, misconfigured or testing scripts, or an insider performing unauthorized probing.

Compromised Accounts

Login Page Brute Force

The first successful login success http request was recorded on 22nd October moments after initial notice of bruteforce activities mentioned in the ELK alerts analysis section



Oct 22, 2025 @ 19:26:29.545	200 /_matrix/client/r0/login	172.29.106.179
Oct 22, 2025 @ 19:26:10.597	200 /_matrix/client/v3/login	172.29.106.179

Figure 19: 172.29.106.179 Successful login after brute-force attack.

Network capture logs show HTTP 200 responses on the Matrix login endpoint (`/_matrix/client/r0/login` and `/v3/login`) from the IP **172.29.106.179** on 22 October. A 200 status code on a login API signifies a successful authentication attempt. This is significant because the same IP was observed attempting credential brute-force and SQL injection on the login page within the same timeframe. Taken together, this pattern strongly suggests that the attacker successfully authenticated at least once, indicating a potential account compromise.

Directory brute force

IOCs

Attacker IPs

- 172.29.108.82: High-volume network traffic to host
- 172.29.108.57: Network anomalies
- 172.29.106.110: Reconnaissance traffic
- 172.29.104.71: Host-to-host probing
- 172.29.105.25: Large-scale 404 directory brute force
- 172.29.104.73: Lightweight reconnaissance + SSH probing
- 172.29.106.179: Login brute force, SQL injection, successful login (200)

Suspicious URL Patterns

- Directory enumeration (hundreds of invalid paths in milliseconds)
- Recon paths: /HNAP1, /sdk, /evox/about
- Login endpoint abuse: repeated POSTs to /_matrix/client/*/login
- SQL injection attempts on login parameters
- Source-map extraction: /bundles/*/playback.worker.js.map

Malicious Tools & Techniques

- nmap-style probing (identified via nmaplowercheck*)
- Automated directory brute force
- Password brute force + account enumeration
- SQL injection probing
- Internal port scanning bursts via /usr/bin/wget

Attack Signatures

- Multiple failed logins with eventual 200 OK login success
- 404 spikes in tens of thousands (automated scanning)
- Repeated SSH attempts using non-existent users
- Short-window multi-port probing (118–119 unique ports)

Root Cause Analysis

- Misconfigured or exposed web endpoints allowed large-scale brute-force directory enumeration.
- Weak or reused credentials likely enabled the successful login observed on 22 October.
- Lack of network segmentation allowed internal reconnaissance (SSH and port probing).
- Insufficient rate-limiting enabled attackers to send thousands of requests within milliseconds.
- Host-level anomalies (Docker lifecycle bursts) were not validated against legitimate system operations.

Technical Timeline (High-Level)

- 22 Oct – Directory brute force begins; first successful login occurs; SQL injection tests observed.
- 22–26 Oct – Massive 404 spikes (>100,000 requests).
- 3 Nov – Final wave of large-scale directory scans.
- 4 Nov – SSH probing from 172.29.104.73 and 172.29.106.168 using non-existent users.
- 7–10 Nov – Repeated internal port-scanning bursts from /usr/bin/wget.
- 7–8 Nov – ML Anomaly High Score spike due to dense container runtime events.

Nature of the Attack

- Phase 1: Web Reconnaissance
 - Directory brute force
 - Recon paths probing
 - Web app structure mapping
- Phase 2: Credential Attacks
 - Login brute force
 - SQL injection probing
 - Confirmed successful authentication
- Phase 3: System-Level Probing
 - SSH user enumeration
 - Internal port scanning bursts
 - Possible compromised internal host involvement
- Phase 4: Post-Compromise Activity (Suspected)
 - Attempt to understand inner application files (*.js.map)
 - Investigation of container runtime behavior

Response and Recovery Analysis

Immediate Response

- Isolate affected host (secops-upanzi-matrix-3), to prevent further reconnaissance, SSH probing, or internal port scans.
- Block malicious IPs at network boundary. Specifically: 172.29.106.179, 172.29.104.73, 172.29.106.168, and other scanning sources.
- Disable compromised credentials. Reset any accounts used during the successful login event on 22 October.
- Terminate suspicious processes. Stop repeated wget scanning bursts and validate container runtime activity.

Containment

- Enforce login rate-limits. Throttle repeated login attempts on both the Matrix API and SSH.
- Apply firewall rules. Restrict access to SSH and Matrix login endpoints to trusted subnets only.
- Review of active sessions. Identify and revoke any sessions established from malicious IPs.

Eradication

- Audit web application for vulnerabilities. Fix exposed endpoints, directory listing issues, and injection points.
- Harden SSH configuration. Disable password authentication, enforce key-based login, and limit user accounts.
- Review Docker/container logs. Confirm whether ML-detected anomalies correspond to legitimate operations.

Recovery

- Re-enable services in monitored mode. Bring systems back online with increased alerting and strict network monitoring.
- Validate system integrity. Perform file integrity checks (Wazuh FIM) and compare against known baselines.
- Apply security patches. Update Matrix server, OS packages, Docker components, and authentication modules.

Post-Incident Improvements

- Enable strict rate-limiting and CAPTCHA on login endpoints. To prevent future enumeration and brute-force attempts.
- Implement network segmentation. Limit lateral movement paths inside the cluster.
- Enhance ML anomaly baselines. Tune models to distinguish legitimate container operations from unusual bursts.
- Regular credential hygiene. Enforce MFA, password policies, and periodic credential rotation for admin accounts.

Hardening scripts: